

Mapeo GQM/PRAGMATIC de métricas STRIDE a requisitos normativos

La tabla siguiente enlaza cada métrica STRIDE definida en el marco GQM con sus objetivos, preguntas asociadas y referencias normativas principales (NIS2, ENS y otros marcos). Este mapeo es coherente con el de la encuesta STRIDE, extendido a nivel de indicador. [web:31][web:34][web:40]

ID Métrica	STRIDE	Objetivo GQM	Pregunta asociada (Q)	Métrica (M)	NIS2 (ejemplos)	ENS (ejemplos)	Otros marcos
S1	S	G-O-S	¿En qué medida están protegidos con MFA los accesos a sistemas críticos?	% de accesos críticos con MFA	Art. 21.2 (medidas técnicas)	PROT.1, PROT.2	NIST SP 800-63
S2	S/E	G-O-S/G-O-E	¿Cómo de gestionadas están las identidades privilegiadas frente a suplantación?	% de cuentas privilegiadas bajo PAM con MFA	Art. 21.2	PROT.1, PROT.4	Zero Trust, CIS Controls
S3	S	G-O-S	¿Cuál es la calidad de autenticación en APIs y M2M críticos?	% de APIs críticas con autenticación fuerte	Art. 21.2	PROT.1, PROT.2	OWASP API Security
S4	S	G-O-S	¿Qué capacidad tiene la organización para detectar intentos de suplantación?	Tasa de intentos de suplantación detectados	Art. 21.2, 23	OP.3, OP.4	NIST CSF Detect

T1	T	G-O-T	¿En qué medida se protege la integridad de logs y datos críticos?	% de sistemas críticos con logs/datos protegidos criptográficamente	Art. 21.2	PROT.2, OP.1	ISO 27001 A.8, A.12
T2	T	G-O-T	¿Cuál es el grado de control sobre la capacidad de modificar datos de negocio?	% de procesos críticos con doble control / SoD	Art. 21.2	ORG.4, PROT.4	Control interno, auditoría
T3	T	G-O-T	¿Qué nivel de garantías de integridad tienen los dispositivos IoT/OT?	% de dispositivos críticos con firmware firmado	Art. 21.2	PROT.3, PROT.7	Guías OT/ICS
R1	R	G-O-R	¿Cuál es la cobertura de logging en sistemas críticos?	% de sistemas críticos con logging centralizado	Art. 21.2, 23	OP.1, OP.2, OP.3	NIST CSF Detect
R2	R	G-O-R	¿Hasta qué punto se garantiza la inmutabilidad y retención de logs?	% de logs críticos en soportes inmutables	Art. 21.2	OP.3, PROT.2	Requisitos probatorios

R3	R	G-O-R	¿Cuán capaz es la organización de reconstruir incidentes?	Tiempo medio para reconstruir un incidente	Art. 23 (notificación)	OP.3, OP.4	NIS2 incident reporting
I1	I	G-O-I	¿Existe inventario y clasificación adecuados de datos sensibles?	% de activos de información clasificados	Art. 21.2	ORG.2, PROT.1	RGPD, ISO 27701
I2	I	G-O-I	¿En qué medida se cifra la información sensible en reposo?	% de datos sensibles cifrados en reposo	Art. 21.2	PROT.2	ENS guías de cifrado
I3	I	G-O-I	¿Qué nivel de protección en tránsito tienen los servicios críticos?	% de flujos críticos bajo TLS fuerte	Art. 21.2	PROT.2	Buenas prácticas TLS
I4	I	G-O-I	¿Se gestionan adecuadamente riesgos en integraciones críticas?	% de integraciones críticas con evaluación de riesgo	Art. 21.2, 23	ORG.4, PROT.5	NIS2 cadena suministro
D1	D	G-O-D	¿Se mide adecuadamente la disponibilidad de servicios críticos?	Horas de indisponibilidad anual por servicio	Art. 21.2	OP.1, OP.5	Continuidad de negocio

D2	D	G-O-D	¿Qué grado de protección DoS tienen los servicios externos?	% de servicios externos críticos con protección DoS/DDoS	Art. 21.2	PROT.3, PROT.5	Mitigación DDoS
D3	D	G-O-D	¿Qué nivel de preparación existe en continuidad?	% de servicios esenciales con planes probados	Art. 21.2	ORG.3, OP.5	ISO 22301, DORA
D4	D	G-O-D	¿Cuál es la resiliencia de las capacidades de seguridad?	% de herramientas de seguridad redundantes	Art. 21.2	OP.3, OP.5	NIST CSF Respond/Recover
E1	E	G-O-E	¿Qué grado de gestión centralizada existe para cuentas privilegiadas?	% de cuentas privilegiadas bajo PAM	Art. 21.2	PROT.1, PROT.4	Zero Trust
E2	E	G-O-E	¿Se aplica el principio de mínimo privilegio?	% de roles/perfiles revisados anualmente	Art. 21.2	PROT.4	Buenas prácticas IAM
E3	E	G-O-E	¿Se revisan y auditan permisos privilegiados?	Nº de revisiones de permisos privilegiados/año	Art. 21.2	ORG.4, OP.3	Auditoría interna

E4	E	G-O-E	¿Cuál es el grado de segregación de funciones?	% de funciones críticas con SoD definida	Art. 21.2	ORG.3, PROT.4	Control interno
G1	GOV	G-O-GOV	¿Existe un proceso formal de threat modeling?	Nivel de formalización (0-3)	Art. 21.2	ORG.1, OP.1	NIST, ISO 27005
G2	GOV	G-O-GOV	¿Qué grado de implantación tiene STRIDE?	% de proyectos críticos con STRIDE	Art. 21.2	OP.1, OP.2	Guías de threat modeling
M1	MET	G-O-MET	¿Se dispone de cuadro de mando alineado con STRIDE?	Índice de cobertura métricas STRIDE	Art. 21.2	ORG.1	Frameworks de madurez
M2	MET	G-O-MET	¿Se usan métricas en decisiones de inversión?	Nº de decisiones justificadas por métricas/año	Art. 21.2	ORG.1	Buen gobierno TI